

Gitwig — Remediation Verification Summary

Target: `gitwig` Rust Git TUI · **Branch:** `audit_remediation` · **Version:** 2.2.1 → **2.2.4** **Re-tested:** 2026-06-30 by Ehsanul Alam Sabbir · against the original `gitwig-Security-Functional-Assessment` baseline. **Method:** independent code re-verification of each fix (not commit-message trust) + dev's own `.agent/audit_remediation_plan.md`. *Note: the full `cargo test` run could not relink in this environment because a `gitwig.exe` (PID 9248) was running and locked the binary — findings below are verified from source + the dev's tracked plan.*

Result:  **Strong remediation — 16 of 19 resolved**

The developer addressed **almost every finding**, with commits referencing the exact IDs. The headline injection and data-loss issues are genuinely closed. **3 items remain** (1 acknowledged-and-deferred, 2 minor/by-design), plus 1 new supply-chain note.

Fixed & verified

ID	Finding	Fix verified in code
S1	Argument injection into git subcommands	<code>--</code> separator added (clone/submodule) + ref-name validation rejecting names starting with <code>-</code> (<code>git.rs:1746</code> , <code>lib.rs:449</code>).
S2	<code>ext::</code> transport not restricted	<code>GIT_ALLOW_PROTOCOL=https:ssh:git:file</code> set on all git shell-outs (<code>git.rs:1739</code> , <code>lib.rs:442</code>).
S3	<code>fzf.excludes</code> → <code>sh -c</code> command injection	Rewritten to <code>Command::new("fd"/"find"/"fzf")</code> with arg-building — no shell interpolation (<code>mod.rs:1911,1940,1986</code>).
S4	Terminal-escape injection from repo data	New <code>sanitize_text()</code> applied to commit author/summary/message/refs (<code>lib.rs:388</code> + ~12 call sites).
S5	World-readable config/log files	Dirs <code>0o700</code> , config/log files <code>0o600</code> , log re-chmods on open (<code>config.rs:506-760</code> , <code>debug_log.rs:62</code>).
S7	Panic on byte-slicing	Length-guarded slicing; char-boundary-safe SHA shortening (<code>debug.rs:48</code> , <code>lib.rs</code>).
S8	Path traversal in built patches	Rejects absolute paths + <code>..</code> components (<code>lib.rs:610,786</code> "Path escapes repository root").

ID	Finding	Fix verified in code
S9	Unbounded debug log	Rotation at 5 MB + 1000-entry cap + secure perms (<code>debug_log.rs:48-63</code>).
R1	Non-atomic config save / startup lockout	Atomic write (<code>.toml.tmp</code> → <code>fs::rename</code>) + corrupt-config recovery (renames bad file, resets to defaults w/ warning) + new regression test (<code>config.rs:359-392,747-764</code>).
F-01	Hidden hard dependency on system <code>git</code>	Startup <code>git --version</code> preflight with clear error (<code>main.rs:69-72</code>).
F-03	"Delete remote branch" only deleted local ref	Now deletes on the remote server (<code>navigation</code> branch-delete).
F-04/F-05	Destructive dialogs defaulted to "Yes"	<code>Enter</code> now maps to Cancel/No on destructive confirms (<code>commit 567a275</code>).
F-08	Theme load hard-failed	Tolerant of file/dir write failures (<code>commit df85e5e</code>).
F-10/F-11	Background-task attribution / stash index shift	Tasks tied to originating repo; stash identity validated on confirm.
F-12	Commit-target index mis-point	Unified via <code>get_selected_commit()</code> ; selection reset on tab/load/search.
F-15	Dead conflict-panel <code>A</code> / <code>C</code> keys	Abort/continue keys now wired (<code>tabs/workspace.rs:249</code> ; <code>commit 690d2bf</code>).

⚠️ What's left

ID	Finding	Status	Detail
F-CRLF	Discard / stage-by-line / stage-by-hunk mishandle CRLF	❌ OPEN — acknowledged & deferred	Dev's own <code>.agent/audit_remediation_plan.md</code> (Q1): <i>"Manually-built patches always use <code>\n</code> ; CRLF files on Windows cause 4/15 core tests to fail, and real hunk/line staging may mis-apply on CRLF repos... Lower priority as the app targets macOS/Linux."</i> Discard still shells out to <code>git apply</code> (<code>lib.rs:739,806</code>); the 4 tests are still active (not ignored). Impact: Windows users on CRLF repos can mis-stage/mis-discard. Fix: preserve original EOL when building patches, or apply via libgit2.

ID	Finding	Status	Detail
S6	SSH <code>StrictHostKeyChecking=accept-new</code>	● Documented only	Behaviour unchanged in code (~14 sites); now <i>documented</i> in README (commit 742fc82) rather than made configurable or defaulted to strict. Acceptable as an informed choice, but still auto-trusts new hosts on first connect.
S3b	<code>Command::new(config.git_ap</code> <code>p)</code> runs an arbitrary configured binary	● By design / accept-risk	Not changed — relies on the user's own config. Consider an allow-list (git / gitu / lazygit) if config can come from an untrusted source.

+ New observation (introduced since baseline)

- **Self-update pipes a remote script to `sh`** — `trigger_self_update()` runs `sh -c "curl ... install.sh \|| sh" / wget ... \|| sh` ([mod.rs:1835,1848](#)). Static strings (not injectable), but it executes remote code with **no checksum/signature** — same `curl \|| sh` supply-chain risk as the installer (S10). Recommend pinning to a released checksum or signed artifact.

Verdict

The remediation is thorough and high-quality — every injection/crypto-adjacent and data-loss finding from the audit is genuinely closed, with fixes matching the recommendations. The remaining items are one **acknowledged Windows-only functional gap (F-CRLF)** and two **informed risk-acceptances** (S6, S3b), plus a **new self-update supply-chain note**.

Recommendation: safe to merge [audit_remediation](#). Before promoting Windows as a first-class target, close **F-CRLF** (EOL-preserving patches or libgit2 apply) and add a checksum to the self-updater.

To get a definitive green test run, close the running Gitwig (PID 9248) and I'll execute `cargo test --workspace` — the build currently can't relink while it holds the binary.

— Remediation verification, gitwig 2.2.4 ([audit_remediation](#)). — Ehsanul Alam Sabbir, 2026-06-30.